PERSONAL PROJECT 2026 · IN PROGRESS

Detecting web skimming before it strikes

Magecart scanner and PCI DSS 4.0 compliance for e-commerce payment pages

The problem: uncontrolled third-party scripts on the payment page

1. Compromise

A third-party or inline script is modified: purchased domain, hijacked CDN, vulnerable CMS.

2. Injection

The malicious code, often obfuscated, runs in the customer's browser.

3. Exfiltration

The card data entered is sent to a domain controlled by the attacker.

Server-side controls cannot see what runs in the browser: this is the principle of Magecart (web skimming).

Magecart: a family of attacks that steal payment data directly in the browser.

A massive, documented threat

2 M+

sites compromised by Magecart attacks since 2015 (DataDome)

100,000+

sites affected by the Polyfill.io compromise in 2024 (initial estimate)

≈ 500,000

British Airways customers affected in 2018, over 15 days

Sources: DataDome, BleepingComputer, Censys / SecurityAffairs, cside. Estimates published by security vendors.

PCI DSS 4.0 brings the browser into scope

Before v4.0, the standard mainly protected the server and data in transit. Two new requirements target client-side skimming.

6.4.3 · Script inventory

All scripts on the payment page are inventoried, justified, authorized, and their integrity is verified.

11.6.1 · Tamper detection

A mechanism alerts when HTTP headers or the content of payment pages are modified.

Mandatory since 31 March 2025 PCI DSS v4.0.1

Sources: PCI Security Standards Council, vendor documentation (Report URI, cside).

The cost of non-compliance

$4.88M

global average cost of a data breach in 2024 (IBM, all sectors)

Contractual penalties via acquiring banks (the PCI SSC does not fine directly)

GDPR penalties in case of a personal data leak

Loss of customer trust, especially for small e-merchants

Source: IBM, Cost of a Data Breach 2024. PCI penalties are applied through acquirers and card brands.

Solutions exist, mostly aimed at large accounts

Vendors	Type of offering
Jscrambler, Feroot, Akamai, Imperva, c/side, Source Defense, Reflectiz	Commercial SaaS solutions
Report URI	CSP / SRI reports

Opportunity to validate

A simple, affordable, compliance-focused solution for e-commerce SMEs (WooCommerce, Shopify).

Non-exhaustive list. SME positioning: hypothesis to be verified through market research.

The solution: a plugin that sees, detects and proves

See

Automatic inventory of the payment page scripts, with a fingerprint (hash) of each one.

Detect

Alert when a script changes, appears, or when data is sent to an unknown domain.

Prove

6.4.3 / 11.6.1 compliance report, exportable for the audit.

End goal: a plugin that a merchant without a security team can install.

MVP v1: what it will contain

1 · Inventory scanner

Playwright loads the payment page, lists external and inline scripts, and computes a SHA-256 hash of each.

2 · Tamper detection

Comparison of hashes and HTTP headers between two scans, alert if a script changes or appears.

3 · Anti-skimming rules

Unknown domains, obfuscated code (base64, eval, atob), suspicious outbound requests.

4 · Compliance report

Justified inventory, change history and timestamped evidence, exportable.

The MVP is the analysis engine plus a minimal interface in a WooCommerce plugin.

How it works: from scan to report

Step 1

Plugin

The merchant installs it and indicates their payment page.

→

Step 2

Scan

The engine loads the page like a real browser.

→

Step 3

Analysis

Hash, allowlist and anti-skimming rules.

→

Step 4

Alert

Email or Slack / Discord webhook when a difference is found.

→

Step 5

Report

Inventory and evidence of changes, exportable.

Next phase: a lightweight JavaScript agent (MutationObserver, PerformanceObserver) to monitor the page in real time in the browser.

Periodic scanning is the basis of the MVP. Real-time monitoring will come later.

PCI DSS requirements covered by the MVP

Requirement	What the standard requires	MVP feature
6.4.3	Inventory, justification, authorization and integrity of scripts	Inventory with hashes, allowlist and justification per script
11.6.1	Detection and alert on modification of headers and content	Comparison between scans, email or webhook alert
Audit	Evidence usable by the auditor	Exportable, timestamped report

Acknowledged limit: a periodic scan does not replace continuous monitoring. It is addressed in phase 2.

The report is meant to help with compliance; it does not replace an assessor's (QSA) evaluation.

From plugin to product

Model (hypothesis)

- Free: script inventory
- Paid: alerts, compliance report, blocking
- Target: SMEs on WooCommerce, then Shopify
- Price: to be defined after market research

Challenges to anticipate

- Workarounds: hidden iframes, WebRTC
- Performance: no perceptible slowdown of the payment
- False positives: stay usable for a non-expert
- Legal: only scan authorized sites

Freemium model: working hypothesis, to be validated before any launch.

Roadmap

In progress

Scoping

PCI DSS requirements, study of Magecart attacks, architecture.

Upcoming

Prototype

Playwright scanner: script inventory and hash.

Upcoming

Test bench

Fake payment page with a harmless skimmer.

Upcoming

Plugin and report

WooCommerce interface, alerts, report export.

Expected result: detect web-skimming cases before exploitation and produce a usable compliance report.